Project Report:

Brute Force Attack Detection Using Windows Security Event Logs

Prepared By:

DIBYANSU BEHERA

E-mail: dibyanshubehera75@gmail.com

LinkedIn: https://www.linkedin.com/in/dibyansu-behera

1. Abstract

This project demonstrates the simulation and detection of a brute force attack against Remote Desktop Protocol (RDP) on a Windows 10 system. The attack was performed using Kali Linux and the Hydra tool to execute a controlled dictionary-based brute force attempt. Windows Security Event Logs were analyzed to identify authentication failures (Event ID 4625) and successful login events (Event ID 4624).

The objective of the project is to understand authentication logging behavior, correlate attack patterns, and develop detection logic suitable for Security Operations Center (SOC) environments.

2. Introduction

Brute force attacks are authentication attacks in which an attacker systematically attempts multiple password combinations to gain unauthorized access to a target system.

Remote Desktop Protocol (RDP), which operates over TCP port 3389, is frequently targeted because it provides remote graphical access to Windows systems.

In real-world SOC environments, detecting brute force attempts early is critical to prevent account compromise, privilege escalation, and lateral movement.

This project simulates such an attack and demonstrates how Windows Security Event Logs can be used to detect and analyze brute force behavior.

3. Objectives

- Simulate a controlled brute force attack on Windows RDP.
- Generate authentication failure and success events.
- Analyze Windows Security Event Logs.
- Correlate failed and successful logins.
- Develop detection logic.
- Propose mitigation and prevention strategies.

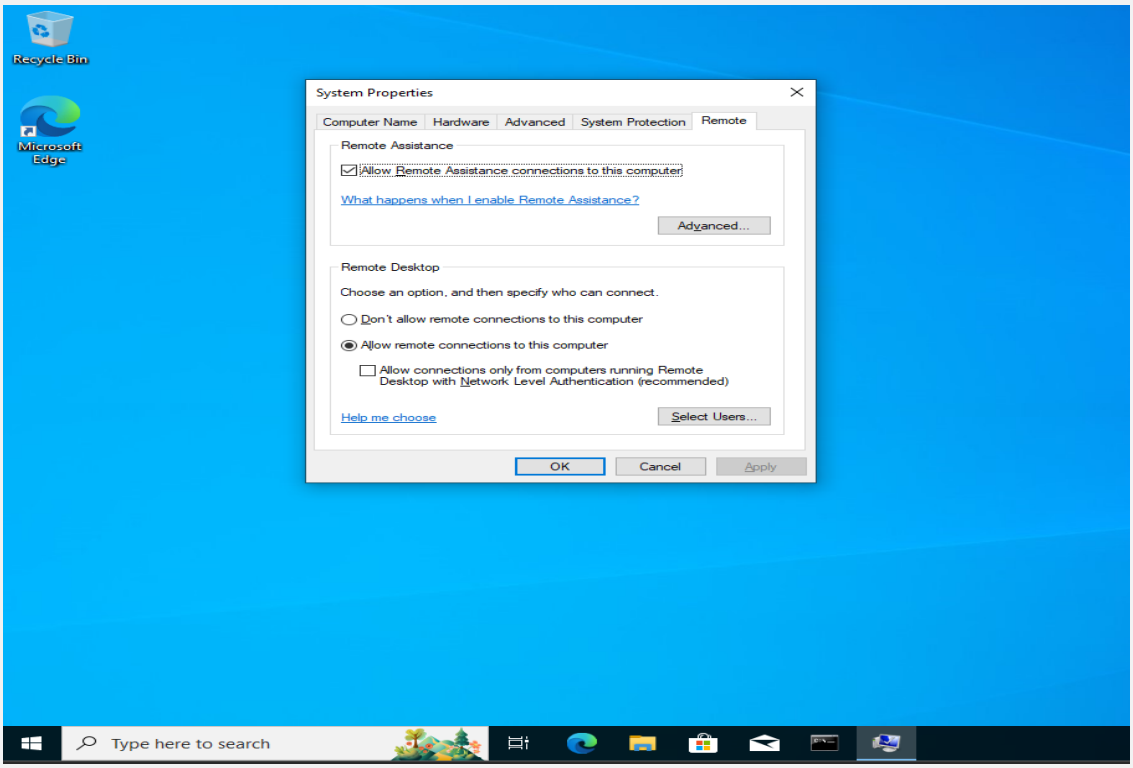
4. Lab Environment

4.1 Infrastructure

Component	Details
Virtualization	VMware Workstation
Attacker Machine	Kali Linux
Target Machine	Windows 10
Network Mode	NAT
Target IP	192.168.240.128
Attacker IP	192.168.240.129
Target Service	RDP (TCP 3389)

4.2 Enabling RDP

Remote Desktop was enabled on Windows 10 to expose the attack surface.



4.3 Verifying Service Availability

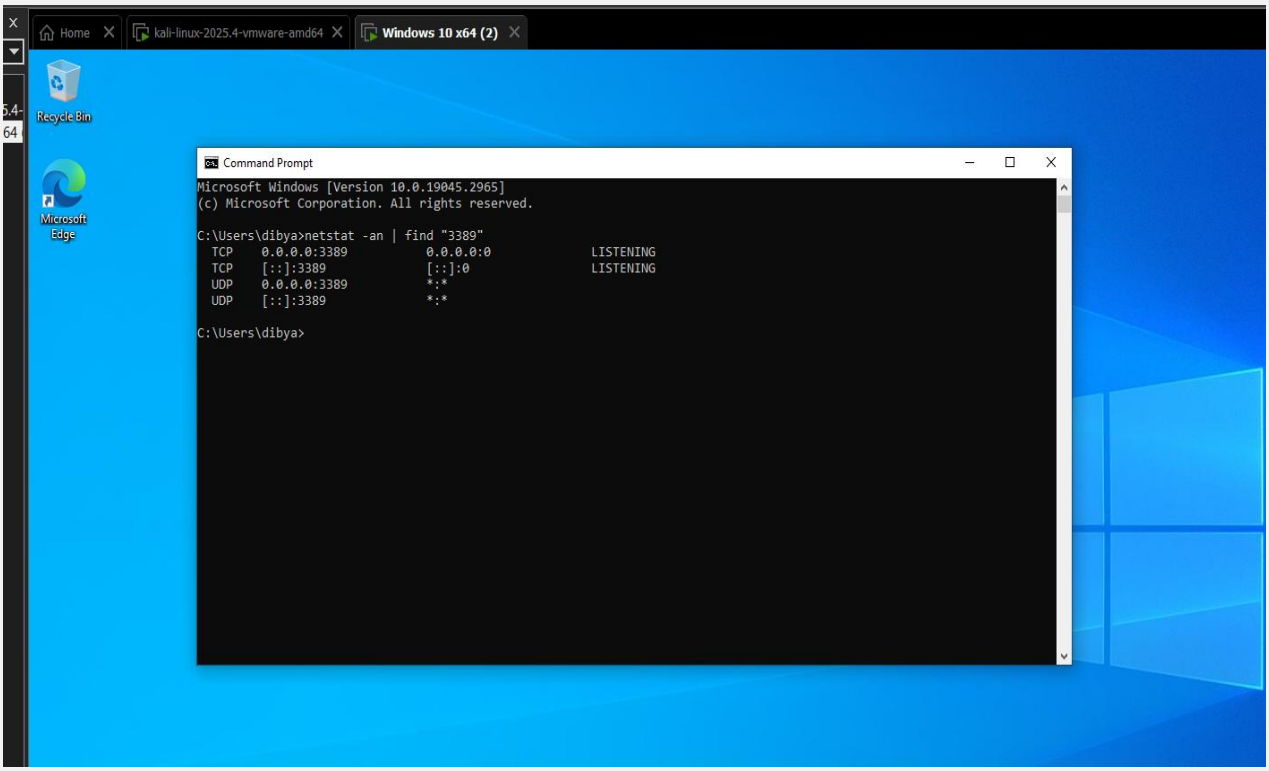
Command executed:

netstat -an | find "3389"

Result confirmed:

0.0.0.0:3389 LISTENING

This verified that the Remote Desktop Service (TermService) was actively listening on TCP port 3389.

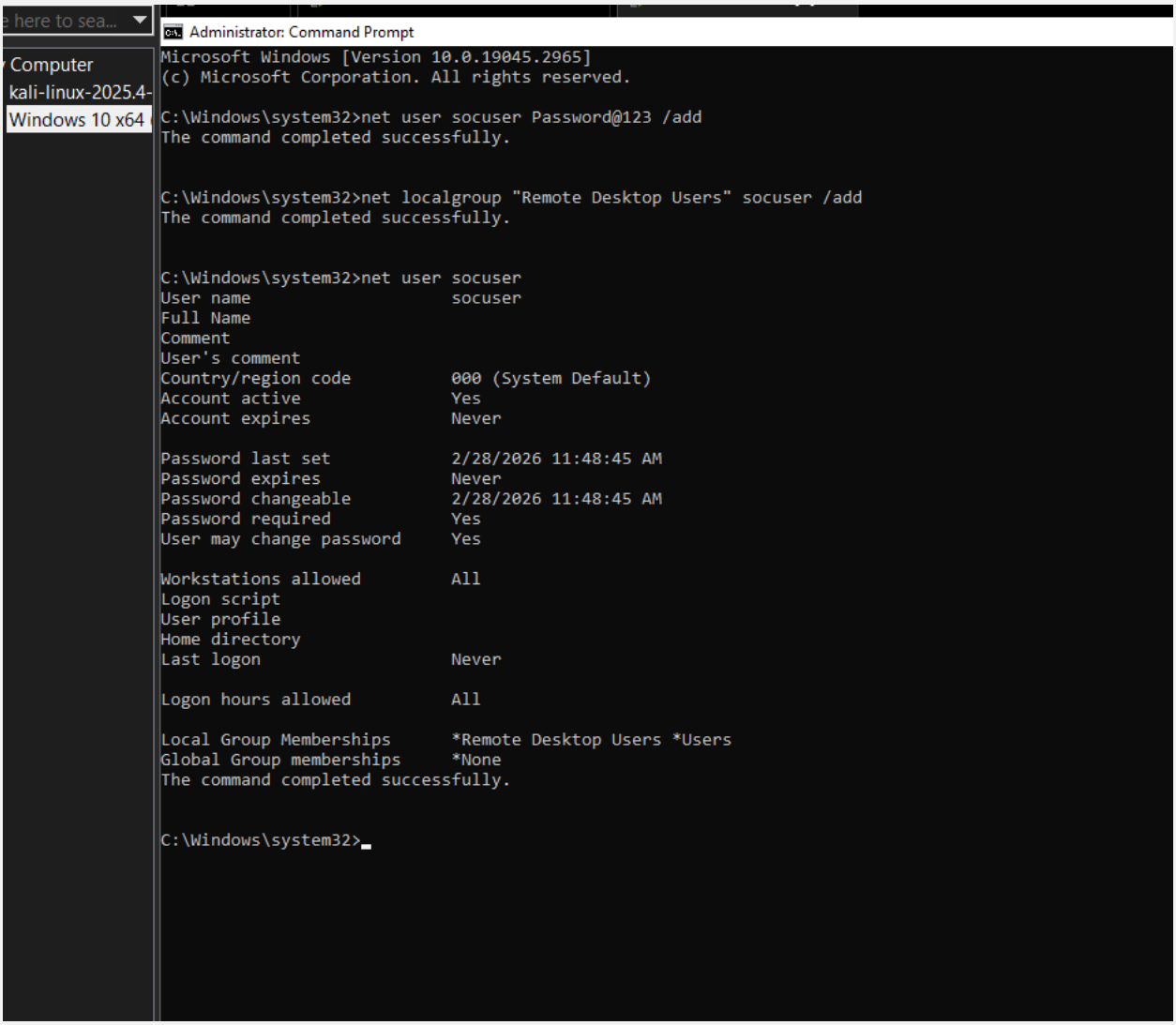


The LISTENING state confirms that the system is actively accepting inbound connections on TCP port 3389. This indicates that the Remote Desktop Service (TermService) is running and properly bound to all network interfaces. Without this state, external authentication attempts would be rejected at the network level. Verifying service availability ensures that the attack simulation is technically valid and that authentication logs will be generated.

4.4 Creating Target Account

A controlled user account was created for attack simulation:

net user socuser Password@123 /add
net localgroup "Remote Desktop Users" socuser /add



This dedicated test account was created to simulate a realistic attack scenario without affecting the primary system user. Assigning the account to the “Remote Desktop Users” group ensured that it was eligible for RDP authentication. Using a controlled account allows accurate log generation and proper correlation of authentication events. This approach maintains isolation and integrity within the lab environment.

5. Technical Background

5.1 RDP and Authentication

RDP supports authentication through:

- NTLM
- Kerberos
- CredSSP (when NLA is enabled)

Authentication attempts are recorded by Windows Security Subsystem in the Security Event Log.

5.2 Windows Authentication Event IDs

Event ID	Meaning
4625	Failed logon
4624	Successful logon
4740	Account locked

5.3 Logon Type Analysis

Logon Type	Description
2	Interactive (local login)
3	Network login
10	RemoteInteractive (RDP GUI session)

Note:

[In this project, Logon Type 3 was observed because Hydra performs NTLM network authentication without creating a full interactive RDP desktop session.]

6. Attack Simulation

6.1 Wordlist Preparation

A custom password list was created:

admin
123456
password
Password@123

The correct password was placed last to simulate multiple failures followed by success.

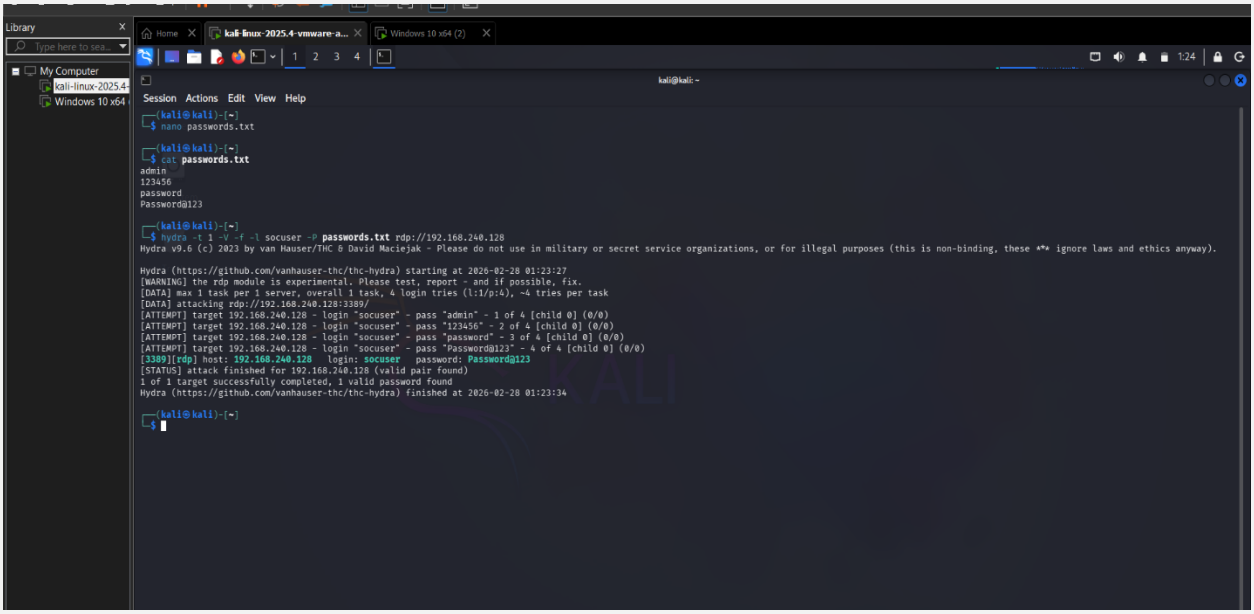
6.2 Hydra Execution

Command used:

hydra -t 1 -V -f -l socuser -P passwords.txt rdp://192.168.240.128

Explanation:

- -t 1 → Single thread for clean logging.
- -V → Verbose output.
- -f → Stop after success.
- -l → Username.
- -P → Password list.



7. Log Analysis

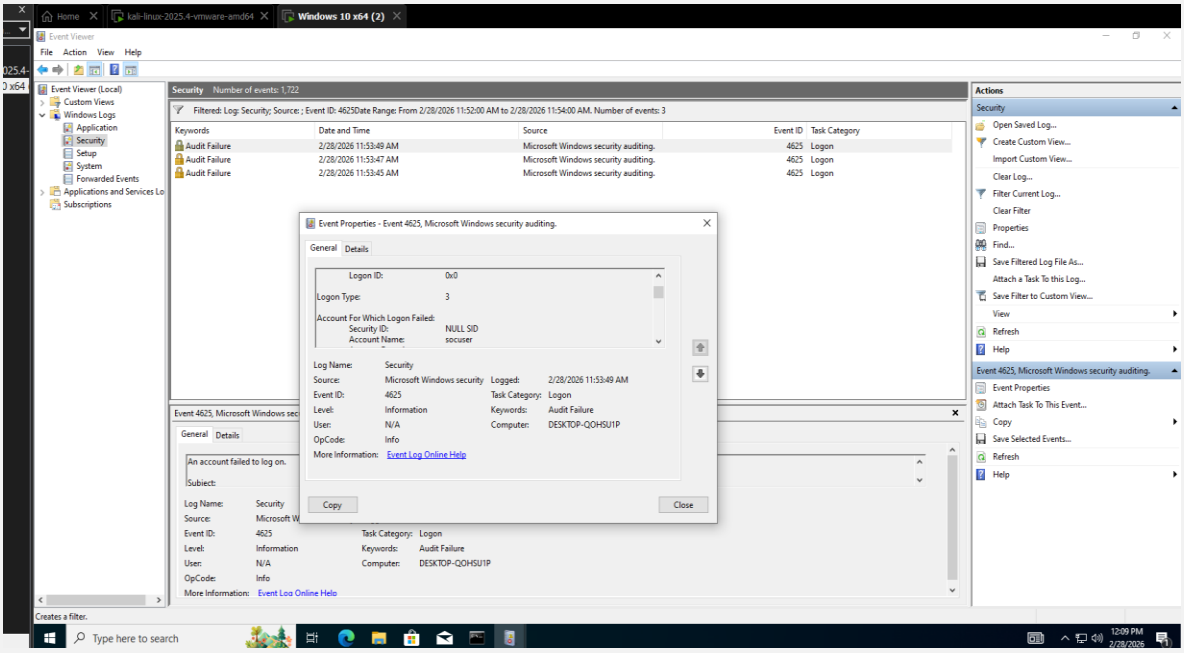
Windows Event Viewer was used:

Event Viewer → Windows Logs → Security

7.1 Event ID 4625 – Failed Logon

Observed:

- Multiple 4625 events.
- Account Name: socuser.
- Source Network Address: 192.168.240.129.
- Authentication Package: NTLM.
- Logon Type: 3.

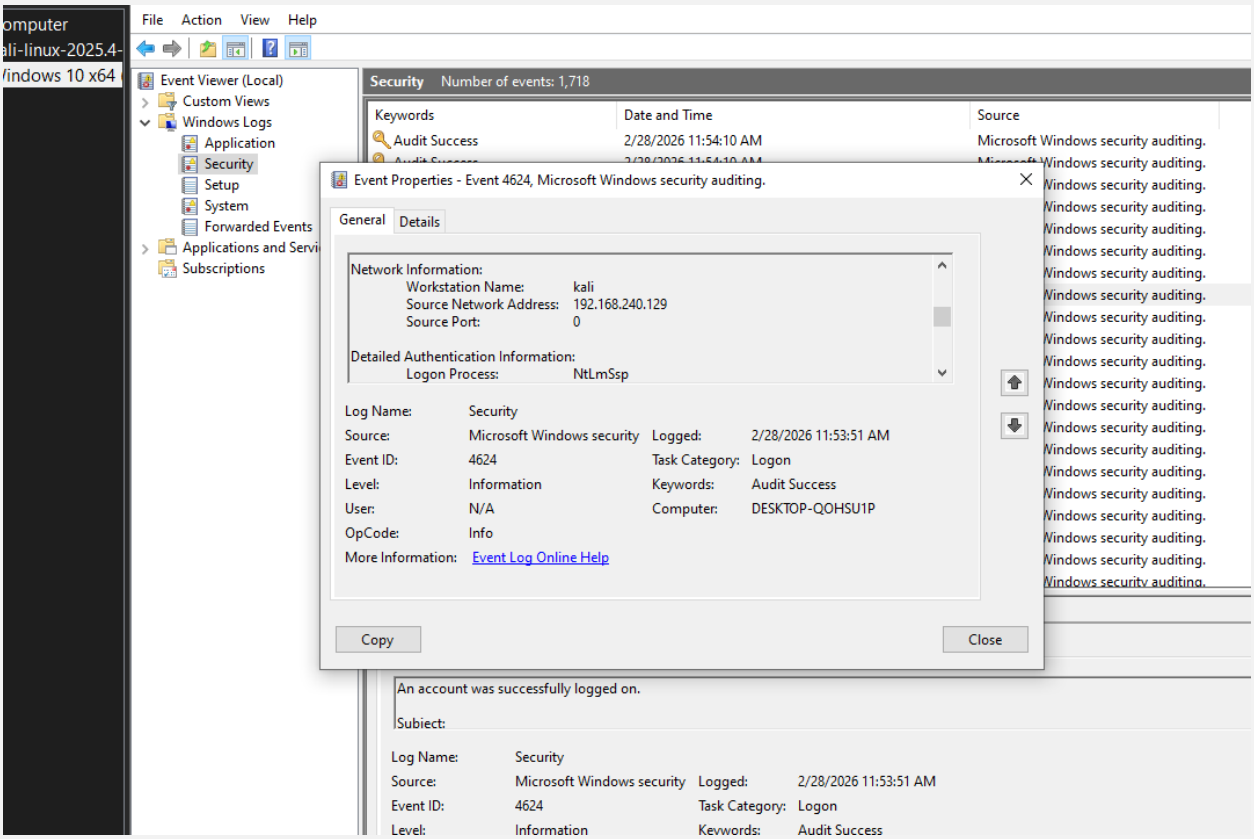


These repeated failed authentication attempts indicate systematic password guessing activity rather than accidental user error. The consistency of the source IP address confirms that all attempts originated from the attacker machine. The short time interval between events further strengthens the evidence of automated brute force behavior.

7.2 Event ID 4624 – Successful Logon

Observed:

- Event ID: 4624.
- Account Name: socuser.
- Source Network Address: 192.168.240.129.
- Authentication Package: NTLM.
- Logon Type: 3.



This event confirms that the authentication attempt from the attacker machine was successful after multiple failed attempts. The correlation between the source IP address (192.168.240.129) and the previous failed login events establishes a clear attack chain. The immediate transition from repeated Event ID 4625 entries to Event ID 4624 indicates successful credential compromise through brute force.

7.3 Attack Pattern Correlation

Sequence observed:

4625 → 4625 → 4625 → 4624

Characteristics:

- Same source IP.
- Same account targeted.
- Occurred within same minute.
- Automated timing behavior.

This confirms a brute force attack pattern.

8. Detection Engineering

8.1 Burst-Based Detection Rule

Trigger alert if:

- Event ID = 4625.
- Same Source IP.
- Same Account.
- ≥ 3 occurrences.
- Within 60 seconds.

8.2 Success Correlation Rule

If:

- Multiple 4625 events occur.
- Followed by Event ID 4624.
- Same IP and same account.

Then escalate alert severity.

8.3 Multi-Account Detection

If:

- Same IP attempts multiple usernames.
- Multiple 4625 events.
- Short interval.

Then classify as password spraying attack.

9. Differentiating User Error vs Brute Force

Normal user behavior:

- 1–3 failed attempts.
- Irregular timing.
- Stops after successful login.
- Same known workstation.

Brute force behavior:

- Repeated rapid attempts.
- Mechanical timing.
- Same IP repeatedly.
- Immediate success after failures.
- Possibly multiple accounts targeted.

Detection must rely on behavioral pattern, not just volume.

Normal user behavior typically involves a small number of failed login attempts (usually 1–3), followed by either a successful login or a pause in activity. The timing between attempts is irregular and human-like, often caused by typing mistakes or forgotten passwords. The login attempts usually originate from a known internal workstation associated with the legitimate user, and the activity stops once access is gained.

10. Mitigation and Prevention

10.1 Technical Controls

- Account lockout after 5 failed attempts.
- Strong password enforcement.
- Enable Network Level Authentication (NLA).
- Restrict RDP using firewall rules.
- Disable direct internet exposure.
- Implement Multi-Factor Authentication (MFA).

10.2 Monitoring Controls

- Centralized logging via SIEM.
- Real-time alert rules.
- Geo-IP anomaly detection.
- Endpoint monitoring.

11. MITRE ATT&CK Mapping

Technique:

T1110 – Brute Force

Tactic:

Credential Access

12. Limitations

- Detection performed manually.
- No centralized SIEM integration.
- Low-and-slow brute force may evade simple thresholds.
- Lab environment does not replicate enterprise complexity.

13. Conclusion

This project successfully demonstrated:

- Controlled brute force simulation.
- Authentication logging behavior.
- Correlation of failed and successful login events.
- Identification of attacker IP address.
- Development of detection logic.
- Implementation of defensive strategies.

The project reflects practical SOC-level understanding of brute force detection using Windows Security Event Logs.